Operation Watchtower — SOC Implementation and Investigation Report

Summary

This report documents the design, implementation, and operational output of Operation Watchtower — a self-contained Security Operations Center built from scratch over two weeks.

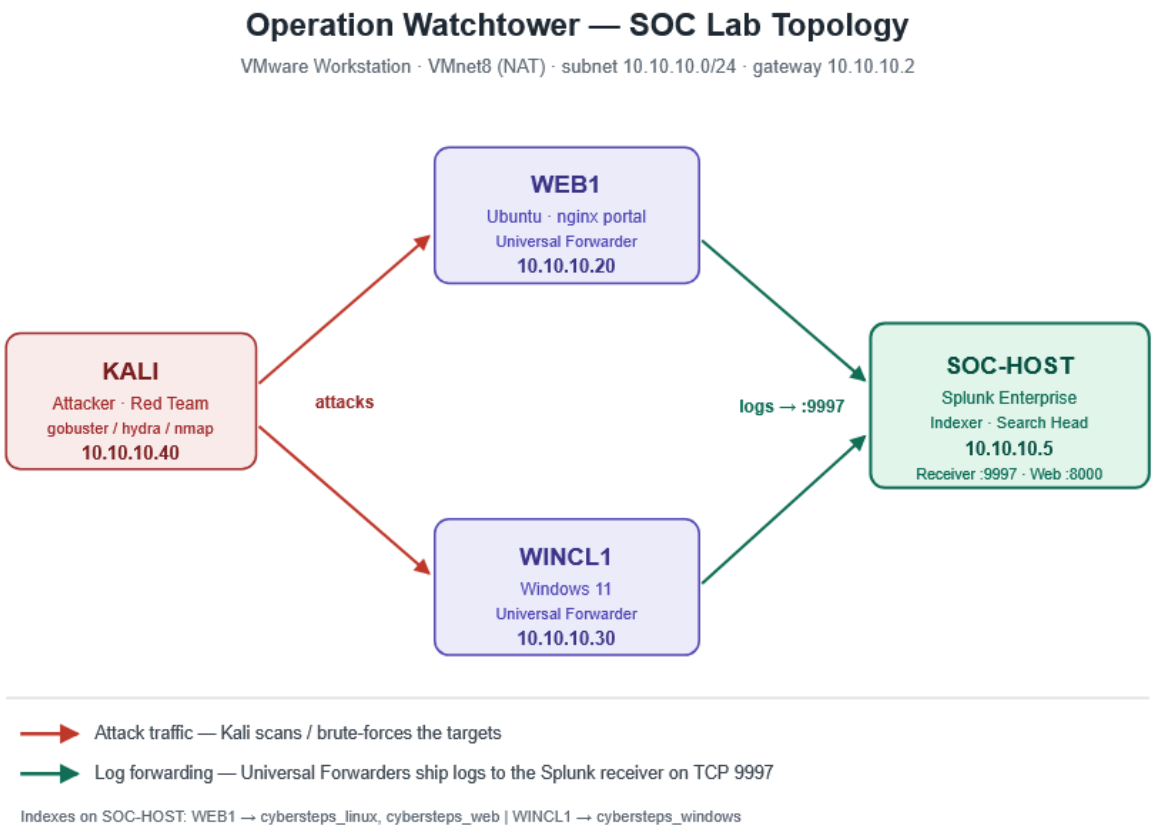
A four-VM lab was deployed on VMware Workstation across an isolated NAT network (10.10.10.0/24), comprising a Splunk Enterprise SIEM on Ubuntu (SOC-HOST), a Linux web server running the CyberSteps internal portal (WEB1), a Windows 11 endpoint (WINCL1), and a Kali Linux attacker machine. Logs from both monitored hosts were collected via Universal Forwarders into three purpose-built Splunk indexes — `cybersteps_linux`, `cybersteps_windows`, and `cybersteps_web` — with Sysmon and PowerShell Script Block Logging deployed on the Windows endpoint for deep process-level visibility

Three operational dashboards were built to answer the four core SOC questions: pipeline health (SOC Health), active threat visibility (Detection Triage), and incident reconstruction (Investigation). The environment at the conclusion of the project can detect, surface, and reconstruct a complete attack chain in real time — the standard this project was designed to meet.

1. Lab Setup

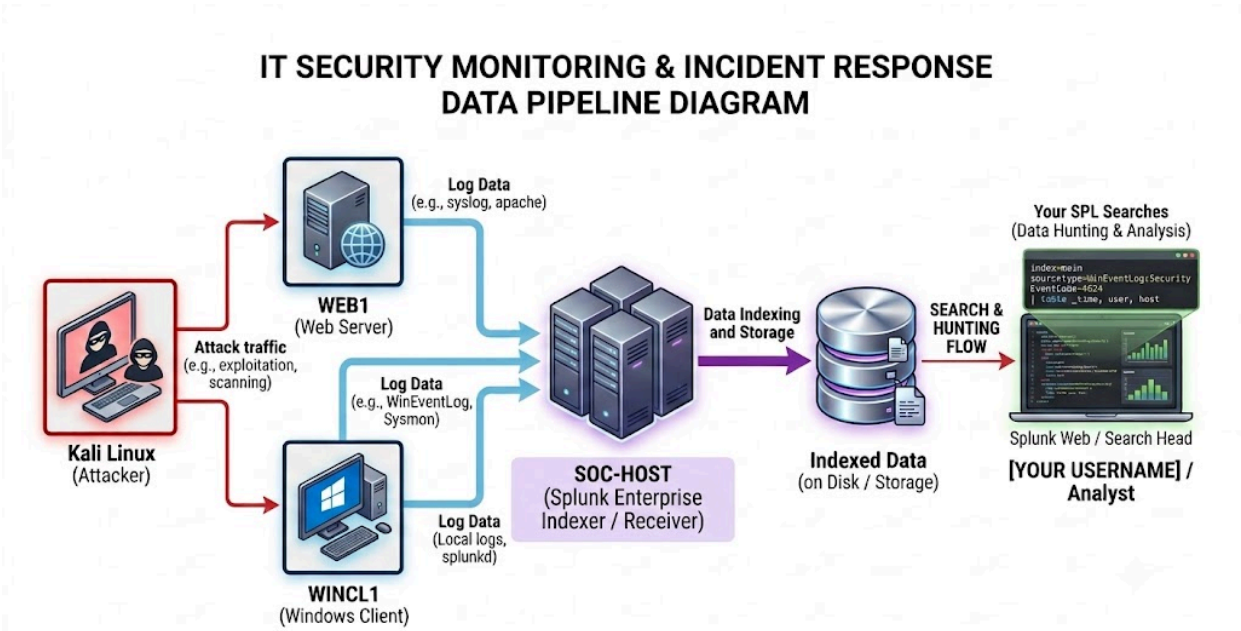
1.1 Environment Description

A four-VM Security Operations Center lab was deployed on VMware Workstation using a NAT network segment (VMnet8, subnet 10.10.10.0/24, gateway 10.10.10.2). Each machine was assigned a stable IP address — SOC-HOST and WEB1 via DHCP reservations by MAC address, WINCL1 via static assignment — so that host identities and forwarder targets remain constant across reboots.

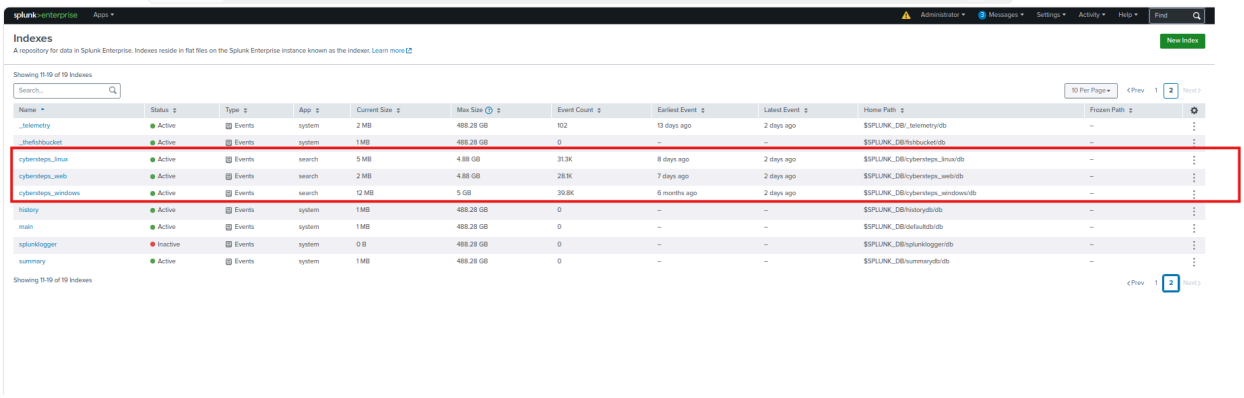


Box	Hostname	IP	OS	Role
SOC-HOST	soc-host	10.10.10.5	Ubuntu Server	Splunk Enterprise — indexer, receiver, search head
WEB1	web1	10.10.10.20	Ubuntu Server (clone)	Linux web server — nginx portal, Universal Forwarder
WINCL1	WINCL1	10.10.10.30	Windows 11	Windows endpoint — Universal Forwarder, Sysmon
Kali	kali	10.10.10.40	Kali Linux 2025.4	Attacker — gobuster, hydra, impacket, crackmapexec

WEB1 was created as a full clone of SOC-HOST (Ubuntu Server), then renamed and given a separate IP reservation.



1.2 How Logs Are Collected:



Log collection follows a forwarder-to-indexer architecture. Each monitored host runs a Splunk Universal Forwarder that tails specified log sources and transmits new events to SOC-HOST over TCP port 9997 — the Splunk-to-Splunk receiving port. SOC-HOST has receiving enabled on this port and writes incoming events into the appropriate index.

WEB1 (Linux) uses file monitors. The forwarder tails:

- `/var/log/syslog` → `sourcetype=syslog` → `cybersteps_linux`
- `/var/log/auth.log` → `sourcetype=linux_secure` → `cybersteps_linux`
- `/var/log/nginx/cybersteps_access.log` → `sourcetype=nginx:access` → `cybersteps_web`

- `/var/log/nginx/cybersteps_error.log` → `sourcetype=nginx:error` → `cybersteps_web`

Note: the CyberSteps portal writes to custom-named log files, not standard nginx defaults. The forwarder service account (`splunkfwd`) was added to the `adm` group to grant read access to `/var/log`.

WINCL1 (Windows) uses the Windows Event Log API (`WinEventLog://` inputs), forwarding:

- `WinEventLog://Security` → `sourcetype=WinEventLog` → `cybersteps_windows`
- `WinEventLog://System` → `sourcetype=WinEventLog` → `cybersteps_windows`
- `WinEventLog://Microsoft-Windows-Sysmon/Operational` → `sourcetype=XmlWinEventLog` → `cybersteps_windows`
- `WinEventLog://Microsoft-Windows-PowerShell/Operational` → `sourcetype=XmlWinEventLog` → `cybersteps_windows`

The Splunk Add-on for Microsoft Windows was installed on SOC-HOST. It normalizes all XML Windows event log sourcetypes to `XmlWinEventLog`, storing the channel name in the `source` field. As a result, all Sysmon searches use `sourcetype="XmlWinEventLog" source="*Sysmon*"` rather than the configured full sourcetype label.

The `NT SERVICE\SplunkForwarder` account was added to the Windows **Event Log Readers** local group to allow the forwarder to read the Sysmon event channel.

Firewall (network) logging: Windows Filtering Platform auditing was later enabled on WINCL1 (`auditpol` — *Filtering Platform Connection* and *Packet Drop*), producing EventCode 5156/5157/5152 in the Security log. These flow through the same `WinEventLog://Security` input into `cybersteps_windows` and feed the port-scan detection (Detection #6). WFP auditing is high-volume, so it was enabled only for testing and disabled afterward.

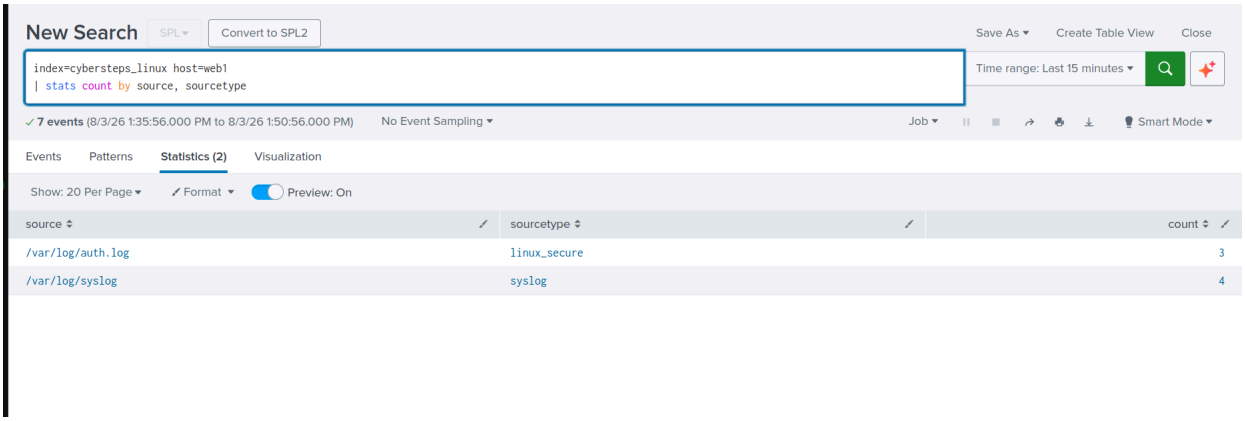
1.3 How Logs Are Structured

Three purpose-built indexes were created on SOC-HOST, each with a maximum size of 5 GB and 30-day retention:

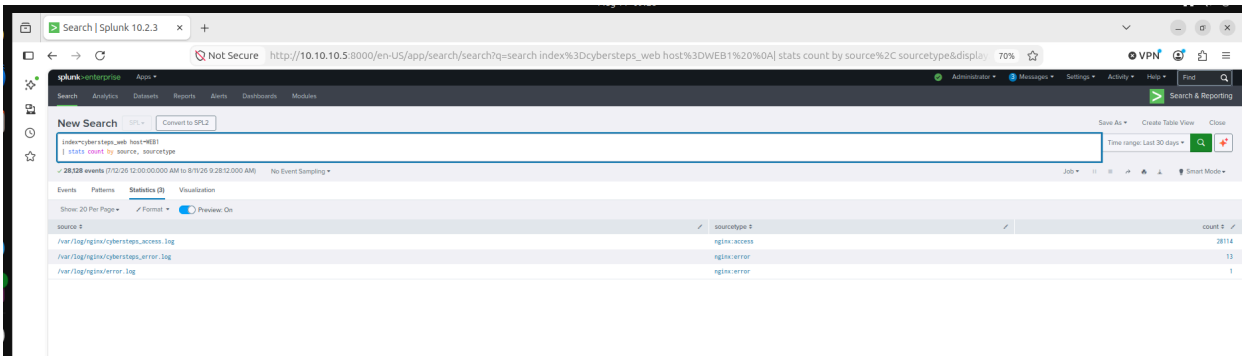
Index	Contents	Source Host	Sourcetypes
`cybersteps_linux`	System messages, authentication logs	WEB1	`syslog`, `linux_secure`
`cybersteps_windows`	Windows Security, System, Sysmon, PowerShell	WINCL1	`WinEventLog`, `XmlWinEventLog`
`cybersteps_web`	nginx access and error logs	WEB1	`nginx:access`, `nginx:error`

Every Splunk event is stamped with four core metadata fields: `host` (originating machine), `source` (log file or channel), `sourcetype` (parsing format), and `index` (destination store).

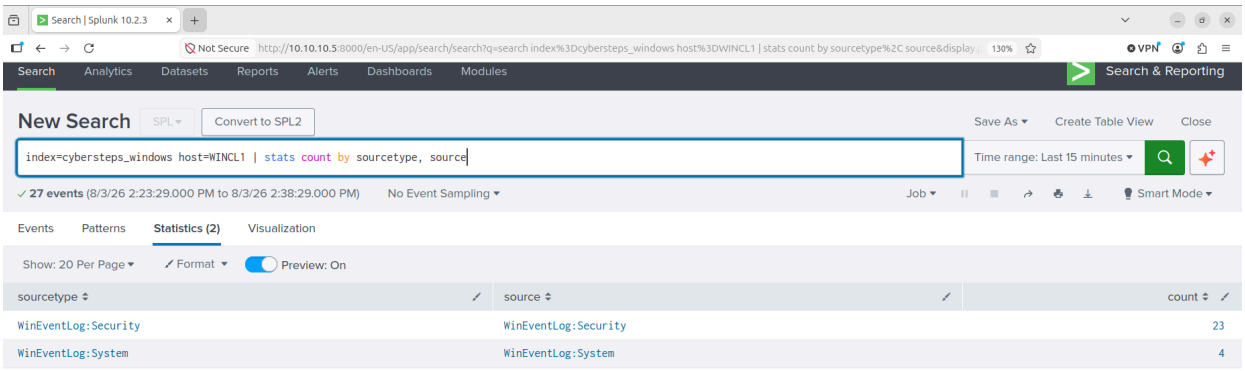
Screenshot below is : index=cybersteps_linux host=web1 | stats count by source, sourcetype — showing /var/log/auth.log (linux_secure: 3) and /var/log/syslog



screenshot: nginx logs from web1:



Screenshot: index=cybersteps_windows host=WINCL1 | stats count by sourcetype, source — showing WinEventLog:Security (21) and WinEventLog:System



1.4 Notable Issues Resolved

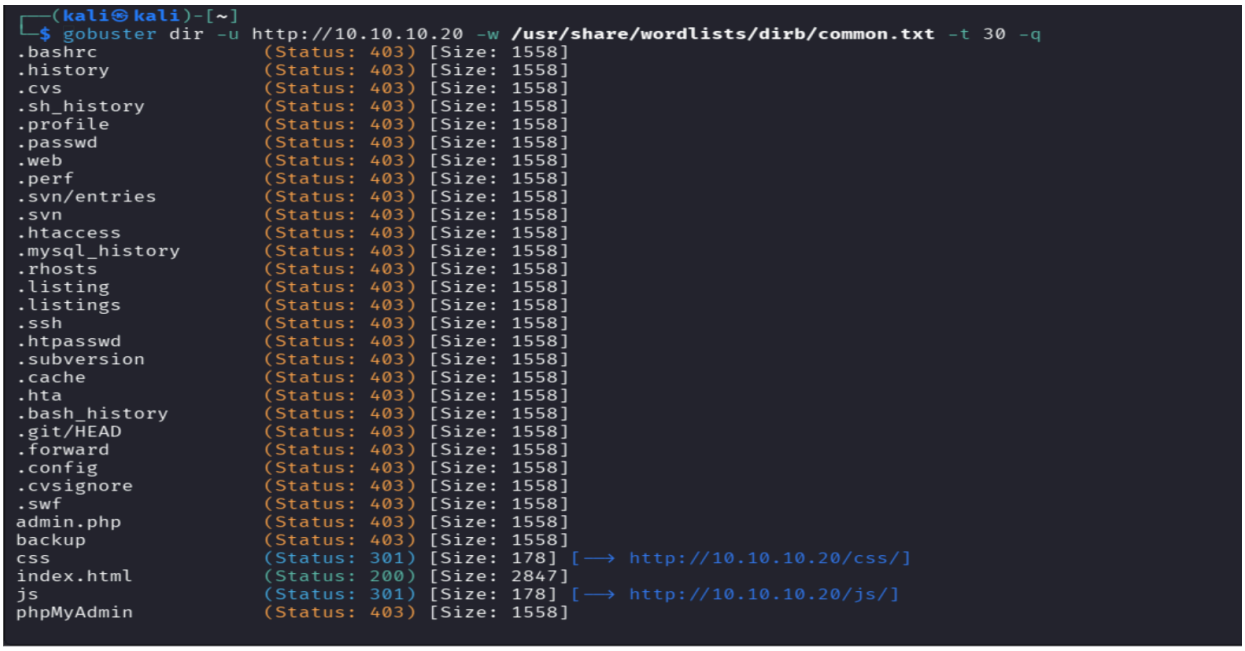
Issue	Root Cause	Resolution
WEB1 forwarder shipped no OS logs	`splunkfwd` not in `adm` group; no read access to `/var/log`	`sudo usermod -aG adm splunkfwd`
Monitor inputs missing index assignment	CLI `add monitor -index` silently dropped the flag	Wrote explicit `inputs.conf` with `index = cybersteps_linux` per stanza
`cybersteps_linux` and `cybersteps_web` missing from receiver	`clean eventdata` left indexes unconfigured on SOC-HOST	Recreated via `splunk add index cybersteps_linux` and `cybersteps_web`
Windows forwarder install failed (MSI error 1603)	Leftover product registration triggered a repair path that crashed on UI font rendering	Removed stale package with `Uninstall-Package`, reinstalled silently with `/qn`
Sysmon events arrived as binary (`\x00\x00`)	`monitor://` input read `.evtx` binary as plain text	Switched to `WinEventLog://Microsoft-Windows-Sysmon/Operational`
Sysmon events not arriving despite correct config	`NT SERVICE\SplunkForwarder` lacked permission to read the Sysmon event channel	Added account to **Event Log Readers** local group
Sysmon searches returned 0 despite data present	Windows TA normalizes sourcetype to `XmlWinEventLog`; full sourcetype label never stored	Changed all Sysmon queries to `sourcetype="XmlWinEventLog" source="*Sysmon*"`
nginx logs not in `cybersteps_web`	Portal writes to `/var/log/nginx/cybersteps_access.log`, not standard `access.log`	Updated `inputs.conf` to monitor the portal-specific log path

2. Detection Pack

Detection #1 — Path Enumeration: Single Source, Many Distinct Paths

Attack simulated: `gobuster dir -u http://10.10.10.20 -w /usr/share/wordlists/dirb/common.txt -t 30 -q`

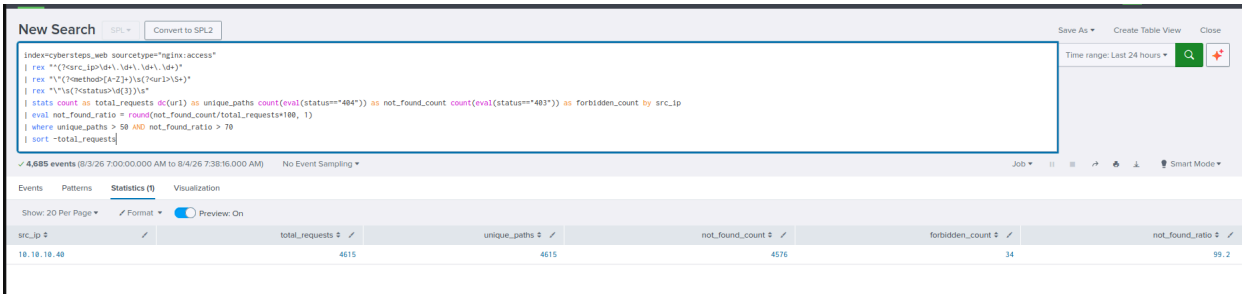
Screenshot: gobuster terminal output:



SPL Query:

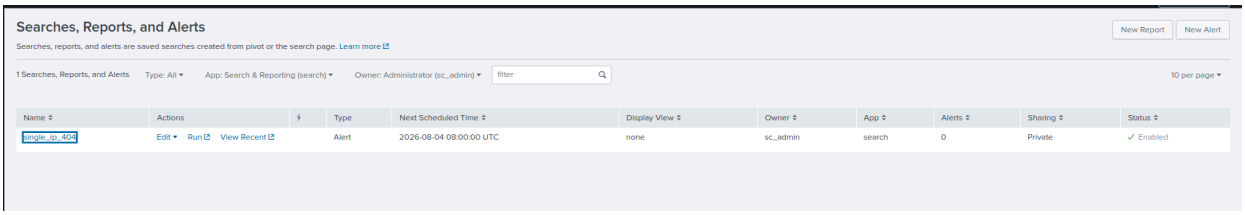
```
index=cybersteps_web sourcetype="nginx:access"
| rex "^(?<src_ip>\d+\.\d+\.\d+\.\d+)"
| rex "\"(?<method>[A-Z]+)\s(?<url>\S+)"
| rex "\"\s+(?<status>\d{3})\s"
| stats count as total_requests dc(url) as unique_paths
    count(eval(status=="404")) as not_found_count
    count(eval(status=="403")) as forbidden_count by src_ip
| eval not_found_ratio=round(not_found_count/total_requests*100, 1)
| where unique_paths > 50 AND not_found_ratio > 70
| sort -total_requests
```

Screenshot: Splunk results showing attack from src_ip: 10.10.10.40



Field	Entry
Threshold	`unique_paths > 50 AND not_found_ratio > 70`
Severity	Low
MITRE ATT&CK	T1595.003 — Active Scanning: Wordlist Scanning
False Positive Notes	Internal vulnerability scanners, uptime/health monitors, legitimate crawlers, or a broken application link generating many organic 404s
Triage Step 1	Is `src_ip` a known internal scanner or external/unexpected address? `10.10.10.40` is the Kali attacker
Triage Step 2	Did any request return 200 (a successful hit worth investigating), or did the IP pivot to POSTs after mapping?

Screenshot: Saved alert `single_ip_404` in Settings → Searches, Reports, and Alerts:



Detection #2 — Brute Force: Repeated Failed Logons

Attack simulated: repeated SMB authentication attempts (NTLM) against `Administrator@10.10.10.30` from Kali generated 233 failed-logon events (EventCode 4625) — 68 bad password, then 165 account locked out as the lockout policy engaged, so the brute force failed and Administrator was never compromised. One successful network logon (EventCode 4624, Logon_Type 3) was then produced for a test account, whose password was deliberately added to the wordlist to demonstrate a successful logon. Reproduced with `rpcclient` and `impacket-smbclient`.

.

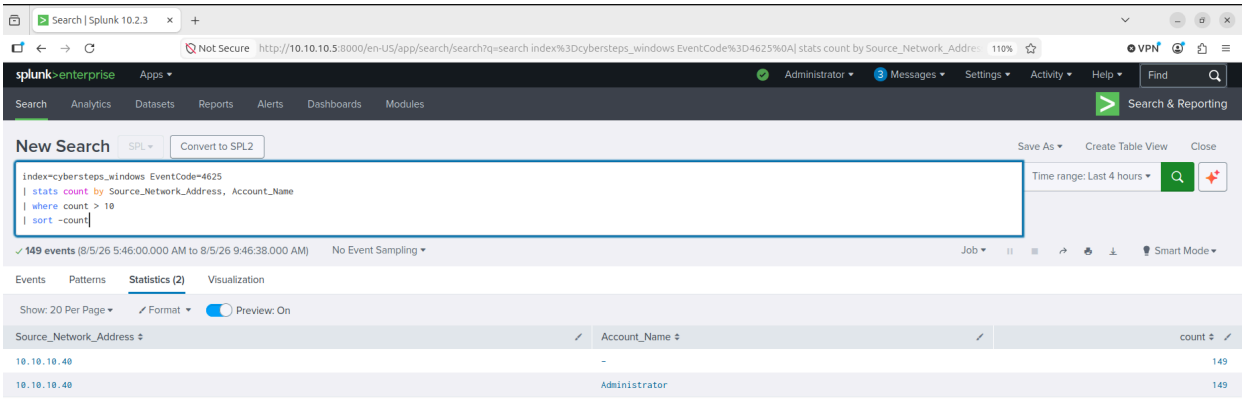
Note: Hydra's SMB module was incompatible with Windows 11's SMBv3 signing enforcement (`signing:True`), returning `invalid reply`. Port 445 was initially filtered; resolved by enabling the

"File and Printer Sharing (SMB-In)" firewall rule. Failed logon auditing required explicit `auditpol /set /subcategory:"Logon" /failure:enable`.

SPL Query:

```
index=cybersteps_windows EventCode=4625
| stats count by Source_Network_Address, Account_Name
| where count > 10
| sort -count
```

Screenshot: Splunk results showing 10.10.10.40 with count > 10 against Administrator account:



Field	Entry
Threshold	`count > 10` failed logons (EventCode 4625) from one source
Severity	High
MITRE ATT&CK	T1110.001 — Brute Force: Password Guessing
False Positive Notes	A user with stale credentials on a mapped drive or scheduled task; a misconfigured service retrying bad credentials; account lockout retry loops
Triage Step 1	Is `Source_Network_Address` a known internal host or an unexpected/external address?
Triage Step 2	Did EventCode 4624 (successful logon) from the same source follow the 4625 failures? Failures then a success indicates likely credential compromise

Detection #3 — Web Login Brute Force: Repeated POST to Login Endpoint

Attack simulated: `hydra -L /usr/share/wordlists/metasploit/unix_users.txt -p admin123 "http-post-form://10.10.10.20/api/auth/login:username=^USER^&password=^PASS^:F=incorrect" -t 10`

Result:
Hydra flooded the login endpoint (`POST /api/auth/login`) with a 175-username list and the password `admin123`. This generated a burst of login POSTs from one IP, which Detection #3 caught. Hydra reported “175 valid”, but that was a false positive: the endpoint returns an identical `204 No Content` for every login, so Hydra’s `F=incorrect` failure condition never matched and it flagged one hit per username (175 = the wordlist length). No credentials were actually compromised — the detection keys on request volume from a single source, not on login success.

```
┌──(kali㉿kali)-[~]
└─$ curl -i -s -X POST http://10.10.10.20/api/auth/login -d 'username=admin&password=admin123'
HTTP/1.1 204 No Content
Server: nginx/1.28.3 (Ubuntu)
Date: Thu, 15 Oct 2026 21:10:47 GMT
Connection: keep-alive
```

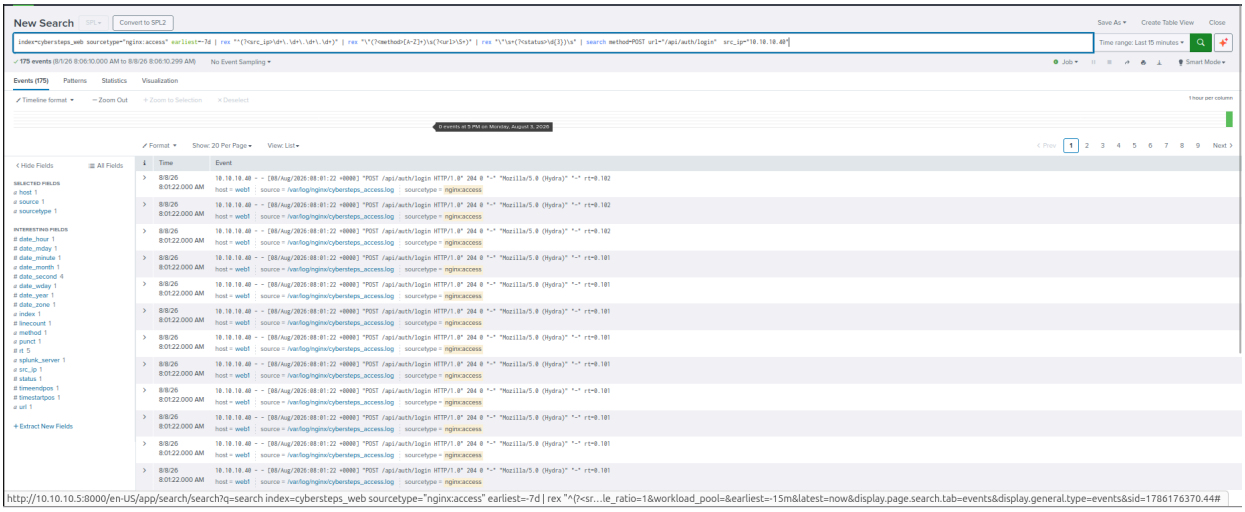
Screenshot: Hydra terminal output — the 175 'valid' results are false positives (every login returns 204 No Content)

```
[80][http-post-form] host: 10.10.10.20   login: ubuntu   password: admin123
[80][http-post-form] host: 10.10.10.20   login: udadmin   password: admin123
[80][http-post-form] host: 10.10.10.20   login: ultra   password: admin123
[80][http-post-form] host: 10.10.10.20   login: umountfs   password: admin123
[80][http-post-form] host: 10.10.10.20   login: umountfsys   password: admin123
[80][http-post-form] host: 10.10.10.20   login: umountsys   password: admin123
[80][http-post-form] host: 10.10.10.20   login: unix   password: admin123
[80][http-post-form] host: 10.10.10.20   login: unscd   password: admin123
[80][http-post-form] host: 10.10.10.20   login: us_admin   password: admin123
[80][http-post-form] host: 10.10.10.20   login: usbmux   password: admin123
[80][http-post-form] host: 10.10.10.20   login: user   password: admin123
[80][http-post-form] host: 10.10.10.20   login: uucp   password: admin123
[80][http-post-form] host: 10.10.10.20   login: uucpadm   password: admin123
[80][http-post-form] host: 10.10.10.20   login: uuidd   password: admin123
[80][http-post-form] host: 10.10.10.20   login: vagrant   password: admin123
[80][http-post-form] host: 10.10.10.20   login: varnish   password: admin123
[80][http-post-form] host: 10.10.10.20   login: web   password: admin123
[80][http-post-form] host: 10.10.10.20   login: webmaster   password: admin123
[80][http-post-form] host: 10.10.10.20   login: whoopsie   password: admin123
[80][http-post-form] host: 10.10.10.20   login: www   password: admin123
[80][http-post-form] host: 10.10.10.20   login: www-data   password: admin123
[80][http-post-form] host: 10.10.10.20   login: xpdb   password: admin123
[80][http-post-form] host: 10.10.10.20   login: xpopr   password: admin123
[80][http-post-form] host: 10.10.10.20   login: zabbix   password: admin123
1 of 1 target successfully completed, 175 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-08 10:01:22
```

SPL Query:

```
index=cybersteps_web sourcetype="nginx:access" earliest=-7d
| rex "^(?<src_ip>\d+\.\d+\.\d+\.\d+)"
| rex "\"(?<method>[A-Z]+)\s(?<url>\S+)"
| rex "\"\s+(?<status>\d{3})\s"
| search method=POST url="/api/auth/login"
| stats count by src_ip
| where count > 20
| sort -count
```

Screenshot: Splunk results showing 10.10.10.40 with count > 20 POST requests to /api/auth/login:



Field	Entry
Threshold	`count > 20` POST requests to `/api/auth/login` from one `src_ip`
Severity	High
MITRE ATT&CK	T1110.003 — Brute Force: Password Spraying
False Positive Notes	Legitimate load-testing tools, broken application retry loops, or multiple users sharing a NAT/proxy IP inflating the count from one address
Triage Step 1	Confirm `src_ip` is not a known internal system or authorized scanner — an external/unexpected address escalates immediately
Triage Step 2	Did any POST to `/api/auth/login` from that IP return HTTP 200? A success response means a valid credential was found

Detection #4 — Process Execution from User-Writable Location

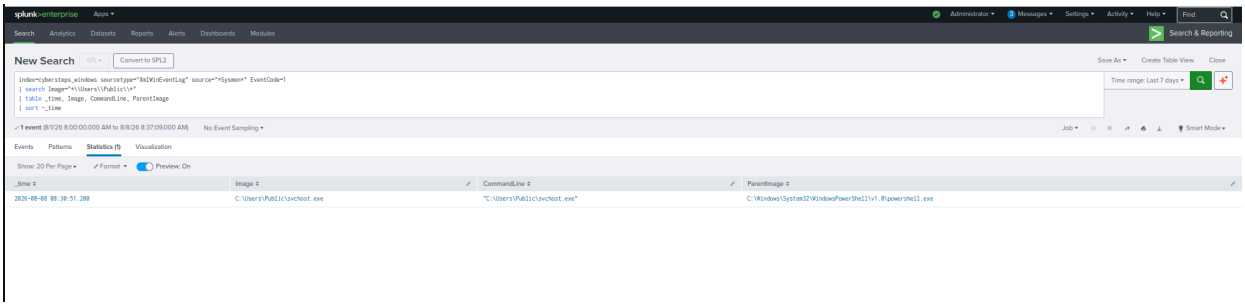
Attack simulated (WINCL1, standard user PowerShell):

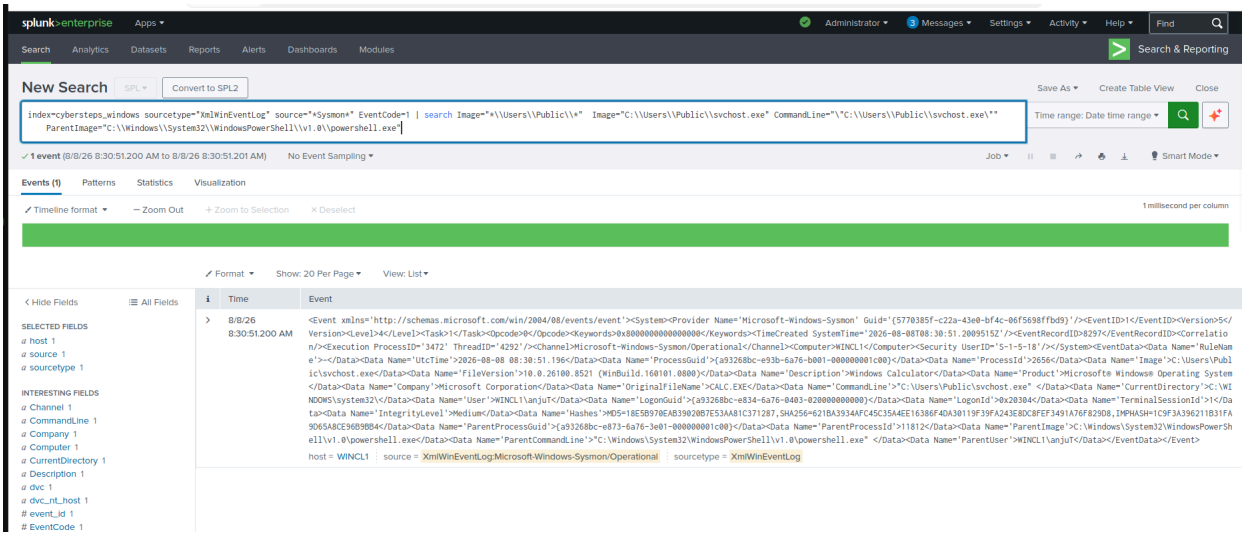
```
Copy-Item "C:\Windows\System32\calc.exe" "C:\Users\Public\svchost.exe"
Start-Process "C:\Users\Public\svchost.exe"
```

SPL Query:

```
index=cybersteps_windows sourcetype="XmlWinEventLog" source="*Sysmon*" EventCode=1
| search Image="*\\Users\\Public\\*"
| table _time, Image, CommandLine, ParentImage
| sort -_time
```

Screenshot: Splunk Sysmon EventCode 1 result showing Image=C:\Users\Public\svchost.exe, CommandLine="C:\Users\Public\svchost.exe", ParentImage=C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe





Field	Entry
Threshold	Any process whose `Image` path contains `\Users\Public\`
Severity	High
MITRE ATT&CK	T1036.005 — Masquerading: Match Legitimate Name or Location
False Positive Notes	Some legitimate software installers temporarily drop helper binaries into Public or Temp folders; portable apps running from user profiles
Triage Step 1	Check the `Image` hash (visible in Sysmon XML) against VirusTotal — is it a known-good renamed system binary (`calc.exe`), a known-bad tool, or unknown?
Triage Step 2	Read `ParentImage` — `powershell.exe` or `cmd.exe` as parent indicates scripted execution; a browser or email client as parent indicates exploitation or phishing delivery

Detection #5 — Persistence: Scheduled Task Created

Attack simulated (WINCL1, elevated Command Prompt):

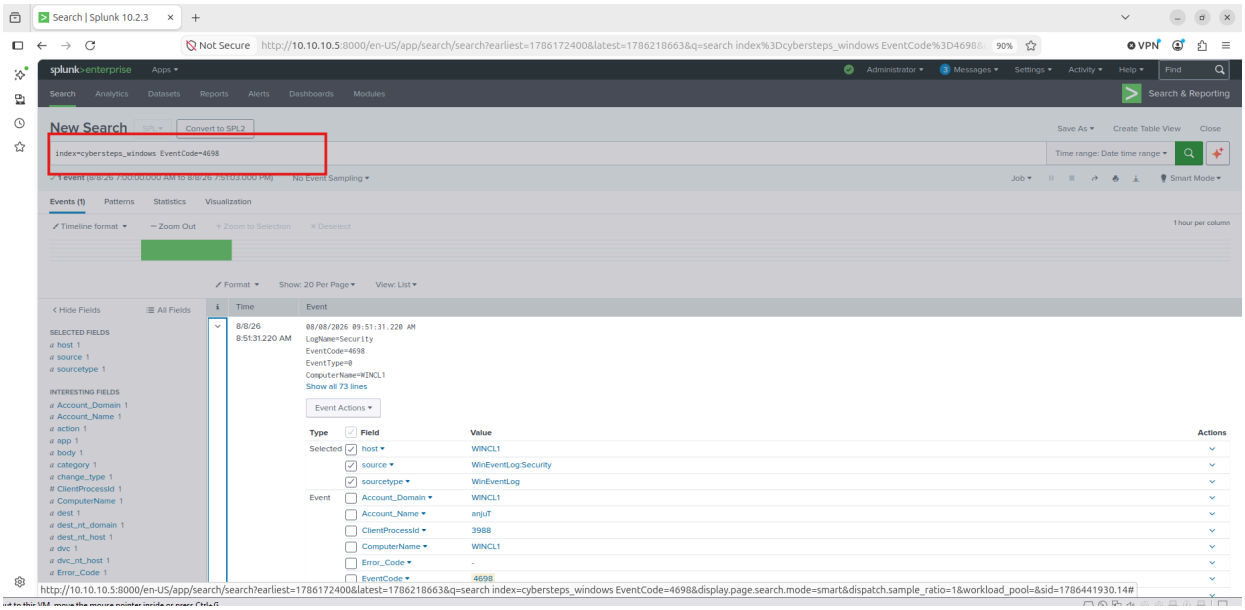
```
schtasks /create /tn "WindowsUpdate" /tr "C:\Users\Public\update.exe" /sc onlogon /ru SYSTEM
```

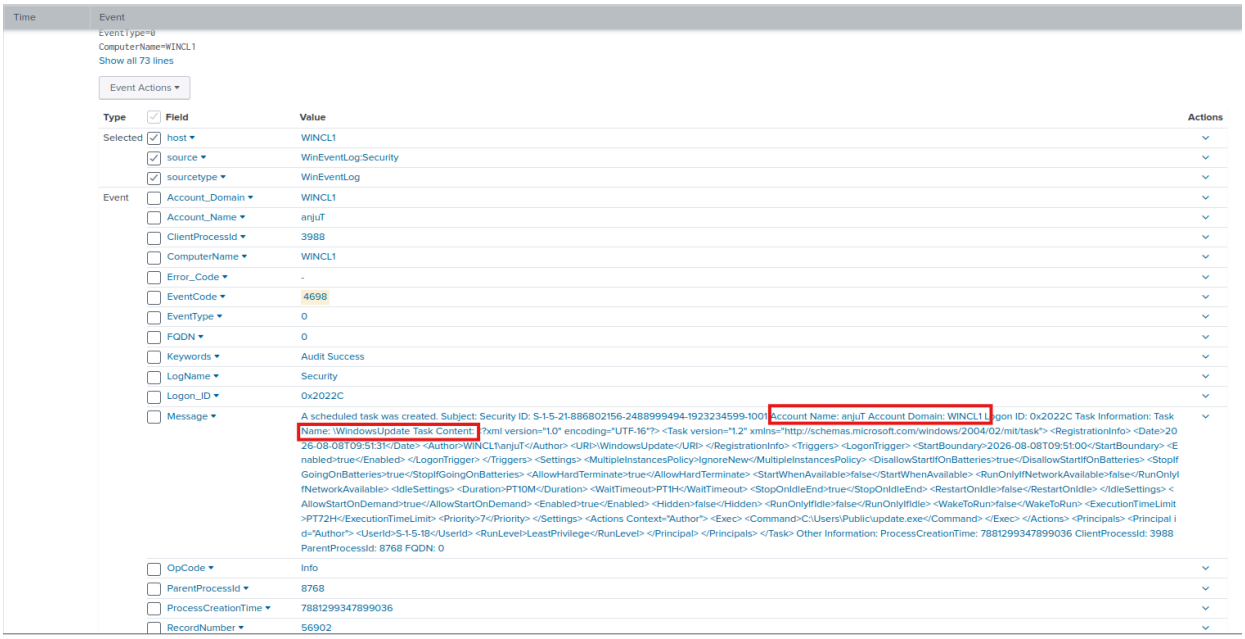
EventCode 4698 appeared after enabling `auditpol /set /subcategory:"Other Object Access Events" /success:enable` and running `gpupdate /force`.

SPL Query:

```
index=cybersteps_windows EventCode=4698
```

Screenshot: Splunk showing 1 event, EventCode=4698, host=WINCL1,





Field	Entry
Threshold	Any result — one task creation is enough to investigate
Severity	Critical
MITRE ATT&CK	T1053.005 — Scheduled Task/Job: Scheduled Task
False Positive Notes	Legitimate software installers and Windows Update commonly create scheduled tasks; IT admin scripts may create them at scale
Triage Step 1	Check `Task_Name` and `Command` — does the task run a binary from `C:\Users\Public\`, `%TEMP%`, or another user-writable path? That is immediate escalation
Triage Step 2	Check `Account_Name` — was this created by a service account, a standard user, or SYSTEM? A standard user creating a SYSTEM-level task is highly suspicious

Detection #6 — Network Service Discovery: Port Scan

Attack simulated (Kali, network-visibility addition): `nmap -sT -p 1-1000 10.10.10.30` (TCP connect scan)

Data source: Windows Filtering Platform audit events (EventCode 5156 allowed / 5157 blocked / 5152 dropped) in the Security log, enabled with `auditpol /set /subcategory:"Filtering Platform Connection"` and `"Filtering Platform Packet Drop"`.

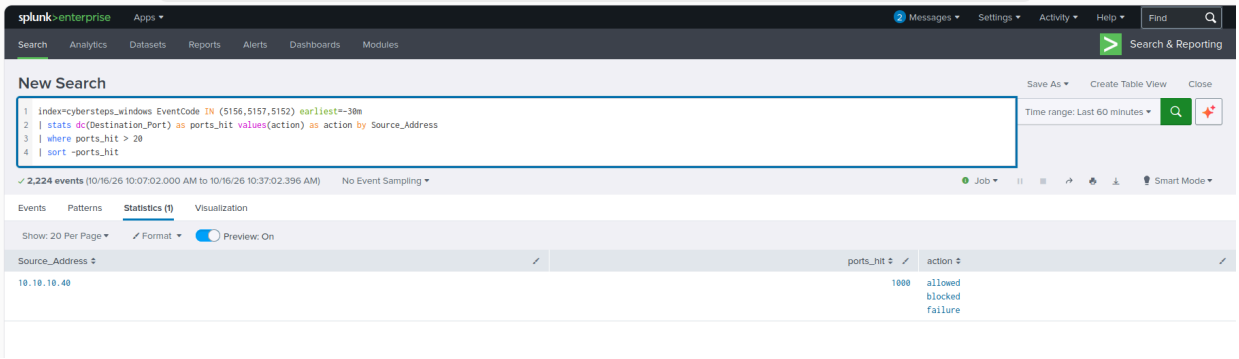
SPL Query:

```
index=cybersteps_windows EventCode IN (5156,5157,5152)
| stats dc(Destination_Port) as ports_hit values(action) as action by Source_Address
```

```
| where ports_hit > 20
| sort -ports_hit
```

Result: `Source_Address 10.10.10.40` contacted **1,000 distinct destination ports** (actions: allowed, blocked, failure) in seconds — an unambiguous port scan.

Screenshot: port-scan detection — 10.10.10.40 with ports_hit = 1,000:



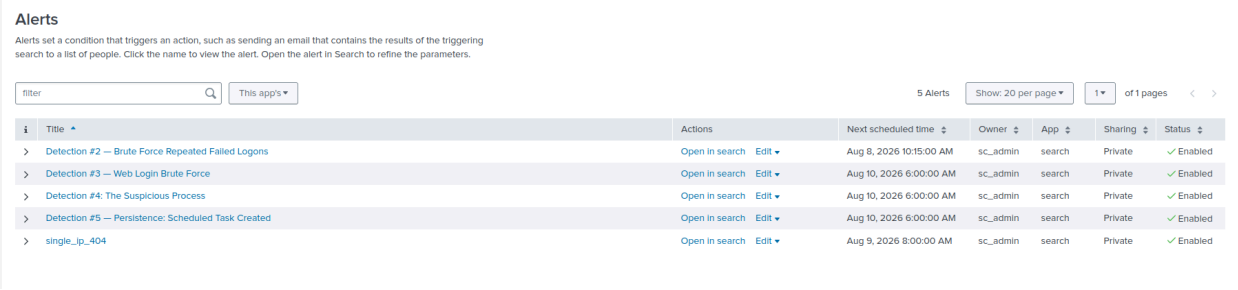
Field	Entry
Threshold	`> 20` distinct destination ports from one `Source_Address`
Severity	Medium
MITRE ATT&CK	T1046 — Network Service Discovery
False Positive Notes	Vulnerability scanners, asset-discovery tools, or backup/monitoring agents that legitimately contact many ports
Triage Step 1	Is `Source_Address` a known scanner / asset-management host, or unexpected?
Triage Step 2	Did the scan precede a connection to an open port (follow-on exploitation)?

Note: WFP connection auditing is high-volume, so it was enabled only for the scan window and disabled afterward to protect the Splunk Free 500 MB/day license.

Saved Alerts Summary

Screenshot: Settings → Searches, Reports, and Alerts showing all 5 alerts Enabled:

These alerts were built and tested during the Splunk Enterprise trial. The lab now runs on Splunk Free (no alerting), so the detections are run as searches with the same logic — all six were re-verified on live data in October.

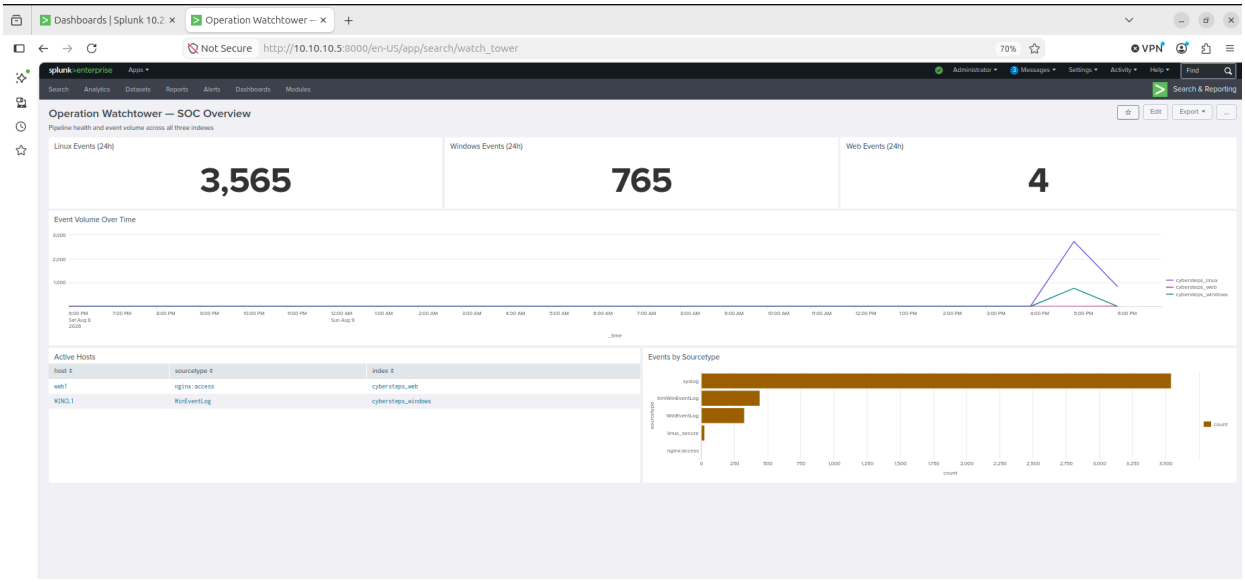


Detection	Saved Alert Name	Severity	MITRE ATT&CK	Triage Notes
Path Enumeration	`single_ip_404`	Low	T1595.003	Is `src_ip` a known scanner? Did any request return 200?
Brute Force Failed Logons	`Detection #2 — Brute Force Repeated Failed Logons`	High	T1110.001	Is `Source_Network_Address` external? Did a 4624 follow the 4625s?
Web Login Brute Force	`Detection #3 — Web Login Brute Force`	High	T1110.003	Is `src_ip` external? Did any POST return HTTP 200?
Suspicious Process	`Detection #4: The Suspicious Process`	High	T1036.005	Check Image hash; read ParentImage
Scheduled Task	`Detection #5 — Persistence: Scheduled Task Created`	Critical	T1053.005	Does Command run from Public? Standard user as SYSTEM?

3. Dashboards

Dashboard 1 — SOC Overview

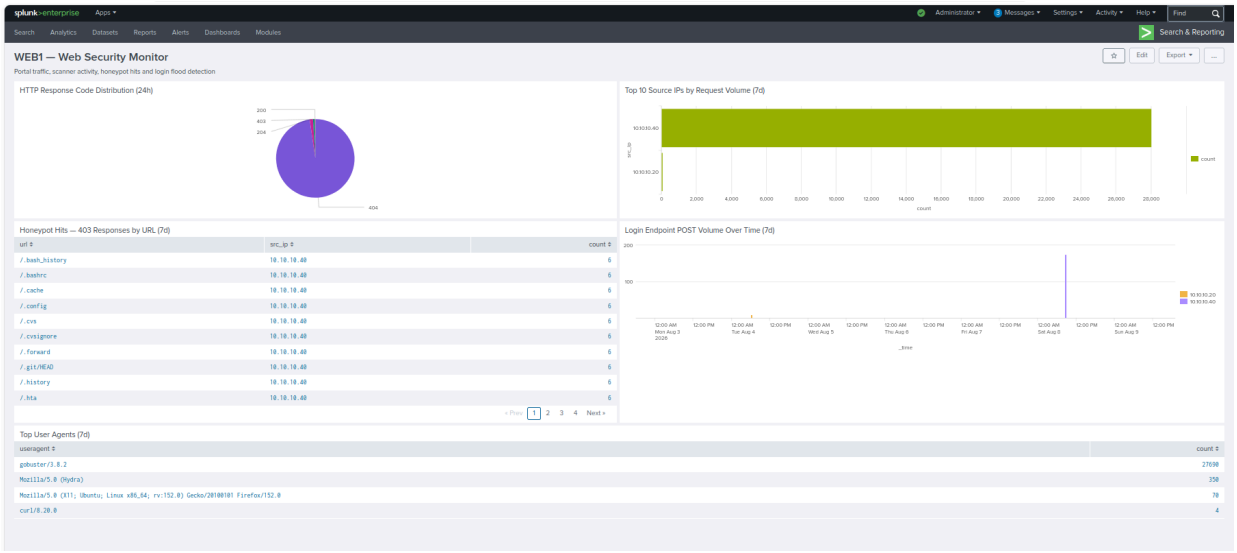
Screenshot: Operation Watchtower — SOC Overview dashboard :



This dashboard confirms the logging pipeline is operational and provides a real-time count of events flowing from each monitored source. Three single-value panels show event totals for `cybersteps_linux` (3,565), `cybersteps_windows` (765), and `cybersteps_web` in the last 24 hours. A line chart shows event volume over time across all three indexes — the spike visible at approximately 4–5 PM on Aug 8 corresponds to attack simulation activity. The Active Hosts table confirms both `web1` and `WINCL1` are reporting. The Events by Sourcetype bar chart shows `syslog` as the dominant source, followed by `XmlWinEventLog` (Sysmon and PowerShell), `WinEventLog` (Security and System), and `linux_secure` — confirming all four sourcetypes are flowing. This is the first screen a shift analyst opens to verify the SIEM is healthy before investigating anything.

Dashboard 2 — Detection Triage

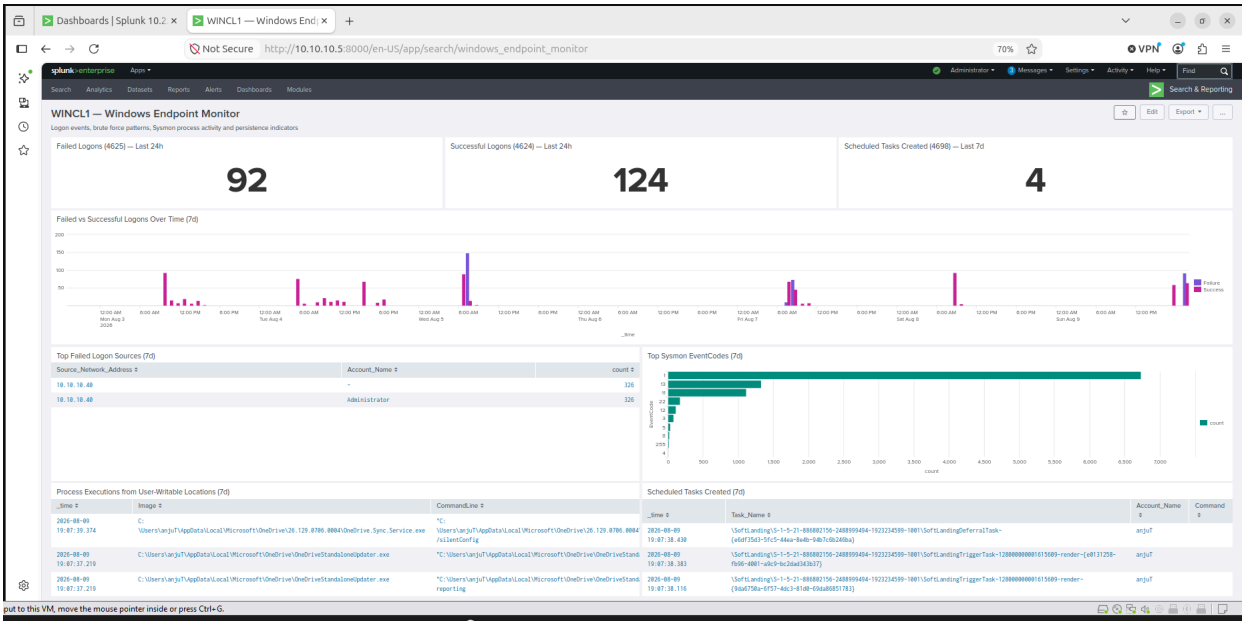
Screenshot: WEB1 — Web Security Monitor dashboard:



This dashboard surfaces active threats on the CyberSteps web portal requiring analyst attention. The HTTP response code pie chart shows that approximately 99.9% of requests from `10.10.10.40` returned 404 or 403 — the definitive fingerprint of automated scanning. The Top Source IPs bar chart confirms Kali (`10.10.10.40`) generated over 27,000 requests over 7 days, dwarfing all legitimate traffic (`10.10.10.20` with minimal self-generated requests). The Honeypot Hits table shows 403-returning paths including `/.bash_history`, `/.git/HEAD`, `/.htpasswd`, `/.config`, and `/.mysql_history` — confirming the scanner reached credential and source-code hunting paths that no legitimate user would visit. The Login Endpoint POST timeline shows a spike corresponding to the Hydra login flood (Detection #3). The User Agents table identifies four tools: `gobuster/3.8.2` (27,690 requests — directory enumeration), `Mozilla/5.0 (Hydra)` (350 — credential brute force), legitimate Firefox (70 — normal browsing), and `curl/8.20.0` (4 — manual probing). Together these panels answer the question: *is anything suspicious happening right now?*

Dashboard 3 — Investigation

Screenshot: WINCL1 — Windows Endpoint Monitor dashboard:



This dashboard supports deep-dive incident analysis on the Windows endpoint and provides the evidence base for reconstructing attack timelines. Three single-value counters show 92 failed logons (EventCode 4625), 124 successful logons (4624), and 4 scheduled tasks created (4698) over the investigation window. The Failed vs Successful Logons column chart shows multiple failure spikes across the week, each corresponding to an impacket SMB brute-force simulation from Kali, with successes visible alongside them. The Top Failed Logon Sources table confirms `10.10.10.40` (Kali) generated repeated failed logons against the Administrator account and anonymous sessions — the core evidence for Detection #2. The Top Sysmon EventCodes bar chart shows EventCode 1 (process creation) dominating at approximately 7,000 events, confirming Sysmon is capturing all process activity. The Process Executions from User-Writable Locations panel shows OneDrive updater processes running from `AppData` — legitimate activity flagged as a known false positive for Detection #4, demonstrating the value of investigating rather than auto-blocking. The Scheduled Tasks table shows four tasks created by the test account, including the `WindowsUpdate` persistence task from Detection #5 alongside legitimate Windows and OneDrive tasks — illustrating why task name alone is insufficient and command path must be examined. This dashboard answers the question: *what exactly happened and in what order?*

---

4. Investigation Report

4.1 Overview

This investigation covers a simulated attack campaign conducted from Kali (10.10.10.40) against WEB1 (10.10.10.20) and WINCL1 (10.10.10.30) between August 3–8, 2026. The

campaign followed a complete kill chain: reconnaissance → credential access → execution → persistence. All five detections fired on real simulated activity.

4.2 Attack Timeline

Time (approx.)	Phase	Action	Host	Detection
Aug 6, 07:11	Reconnaissance	`gobuster` directory scan against portal — 4,615 requests generated	WEB1	Detection #1 (`single_ip_404`)
Aug 6, 07:11	Reconnaissance	14 honeypot paths hit (403): `/.git/HEAD`, `/.htpasswd`, `/.bash_history` etc.	WEB1	Detection #1
Aug 8, 08:01	Credential Access	Hydra login flood — 353 POST attempts to `/api/auth/login`	WEB1	Detection #3
Aug 5, 07:43–07:44	Credential Access	SMB brute force — 233 failed logons (68 bad password, 165 lockout) from 10.10.10.40	WINCL1	Detection #2
Aug 5, 07:43–07:44	Credential Access	Seven ANONYMOUS LOGON 4624 events (SMB session negotiation artefacts)	WINCL1	—
Aug 8, 08:30	Execution	`calc.exe` copied to `C:\Users\Public\svchost.exe` and executed	WINCL1	Detection #4
Aug 8, 09:51	Persistence	Scheduled task `WindowsUpdate` created, runs `C:\Users\Public\update.exe` as SYSTEM	WINCL1	Detection #5

4.3 Evidence Per Phase

Phase 1 — Reconnaissance (Detection #1)

Gobuster generated 4,615 HTTP requests against `http://10.10.10.20` in under 30 seconds. Response code breakdown: 404 (4,576), 403 (34 honeypot hits), 200 (5), 301 (2). The 99.9% non-success rate and 4,615 distinct URL paths in a single minute are impossible for a human browser — the behavioral signature of a wordlist scanner.

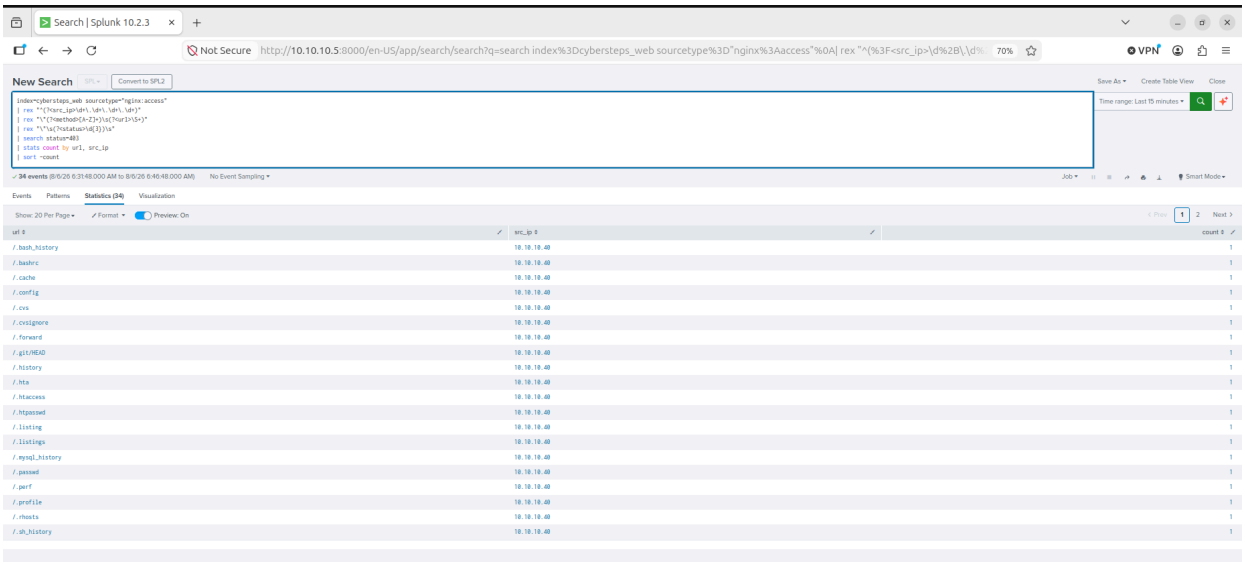
Honeypot paths hit (status 403, all from 10.10.10.40):
`/.bash_history`, `/.bashrc`, `/.cache`, `/.config`, `/.cvs`, `/.cvsignore`, `/.forward`, `/.git/HEAD`, `/.history`, `/.hta`, `/.htaccess`, `/.htpasswd`, `/.listing`, `/.listings`, `/.mysql_history`, `/.passwd`, `/.perf`, `/.profile`, `/.rhosts`, `/.sh_history` and others.

The paths `/.git/HEAD` and `/.htpasswd` are the highest-concern hits — they indicate the attacker was specifically hunting for source code repositories and credential stores.

SPL used for evidence:

```
index=cybersteps_web sourcetype="nginx:access" earliest=-7d
| rex "^(?<src_ip>\d+\.\d+\.\d+\.\d+)"
| rex "\"(?<method>[A-Z]+)\s(?<url>\S+)"
| rex "\"\s+(?<status>\d{3})\s"
| search status=403
| stats count by url, src_ip
| sort -count
```

[Screenshot: Honeypot hits table — url column listing /.bash_history, /.git/HEAD etc., all from 10.10.10.40 — from The Honeypot Knows task results]



Phase 2 — Credential Access — Web Login Flood (Detection #3)

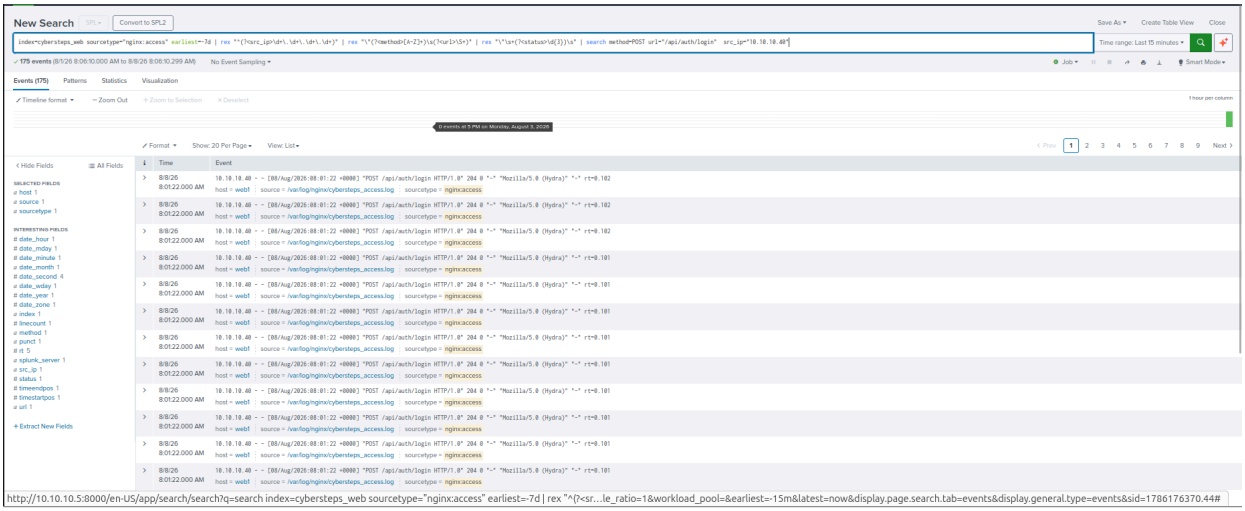
Hydra sent POST requests to /api/auth/login using a username wordlist with the password admin123, generating a burst of over 20 POSTs from a single IP that triggered Detection #3. Hydra reported "175 valid", but this was a false positive: the endpoint returns an identical 204 No Content for every login, so Hydra's F=incorrect condition never matched and it flagged one hit per username (175 = the wordlist length). No credentials were validated; the detection keys on request volume from one source, not on login success.

SPL used for evidence:

```
index=cybersteps_web sourcetype="nginx:access" earliest=-7d
| rex "^(?<src_ip>\d+\.\d+\.\d+\.\d+)"
| rex "\"(?<method>[A-Z]+)\s(?<url>\S+)"
```

```
| rex "\"\s+(?<status>\d{3})\s"
| search method=POST url="/api/auth/login"
| stats count by src_ip
| where count > 20
| sort -count
```

Screenshot: Splunk results showing 10.10.10.40 with count > 20 POSTs to /api/auth/login:



Phase 3 — Credential Access — SMB Brute Force (Detection #2)

SMB brute force was run from 10.10.10.40 against 10.10.10.30. Hydra's SMB module and crackmapexec/nxc could not authenticate against Windows 11 SMBv3 signing (invalid reply / NETBIOS timeout); impacket's SMBConnection authenticated cleanly. 233 failed-logon events (EventCode 4625) were recorded against the Administrator account — 68 "bad password", then 165 "account locked out" — so the brute force failed and Administrator was never compromised. The same source produced 7 EventCode 4624 ANONYMOUS LOGON (Logon_Type 3) SMB session-establishment artefacts, plus one deliberate successful logon (Logon_Type 3) using a valid test account whose password was added to the wordlist, to demonstrate what a successful logon looks like.

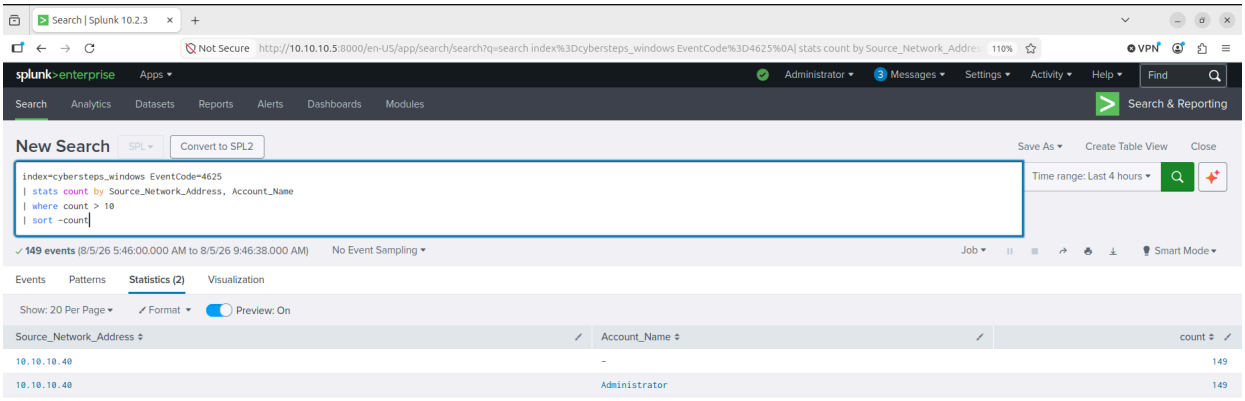
SPL used for evidence:

```
index=cybersteps_windows EventCode=4625
| stats count by Source_Network_Address, Account_Name
| where count > 10
| sort -count
```

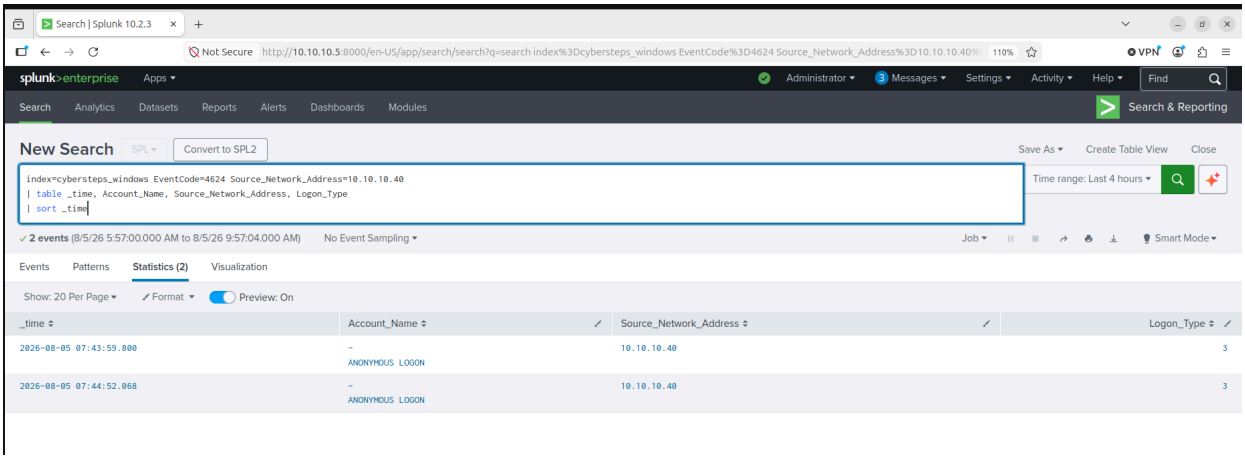
Triage query — check for post-failure success:

```
index=cybersteps_windows EventCode=4624 Source_Network_Address=10.10.10.40
| table _time, Account_Name, Source_Network_Address, Logon_Type
| sort _time
```

Screenshot: 4625 stats showing 10.10.10.40 — Administrator (233: 68 bad password + 165 locked out)



Screenshot: 4624 results showing ANONYMOUS LOGON Logon_Type=3



Phase 4 — Execution (Detection #4)

A legitimate Windows binary (`calc.exe`) was copied from `System32` to `C:\Users\Public\svchost.exe` and executed. Sysmon EventCode 1 captured the process creation. Key fields from the event:

- `Image`: `C:\Users\Public\svchost.exe`

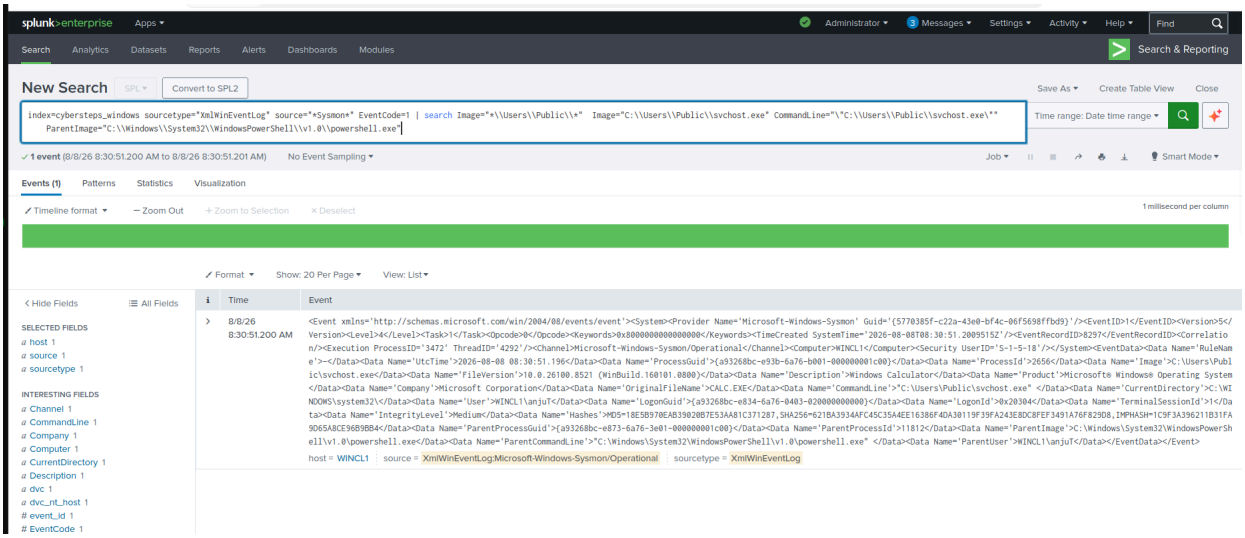
- `CommandLine`: `"C:\Users\Public\svchost.exe"`
- `ParentImage`: `C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe`

The combination of a trusted binary name (`svchost.exe`) in a user-writable location (`C:\Users\Public\`) launched by PowerShell is the masquerading pattern Detection #4 was designed to catch.

SPL used:

```
index=cybersteps_windows sourcetype="XmlWinEventLog" source="*Sysmon*" EventCode=1
| search Image="*\\Users\\Public\\*"
| table _time, Image, CommandLine, ParentImage
| sort -_time
```

Screenshot: Sysmon EventCode 1 result — Image=C:\Users\Public\svchost.exe, ParentImage=powershell.exe:



Phase 5 — Persistence (Detection #5)

A scheduled task was created to establish persistence across reboots:

```
schtasks /create /tn "WindowsUpdate" /tr "C:\Users\Public\update.exe" /sc onlogon /ru SYSTEM
```

EventCode 4698 recorded the creation. Key fields:

- `Task_Name`: `\WindowsUpdate`
- `Command`: `C:\Users\Public\update.exe`

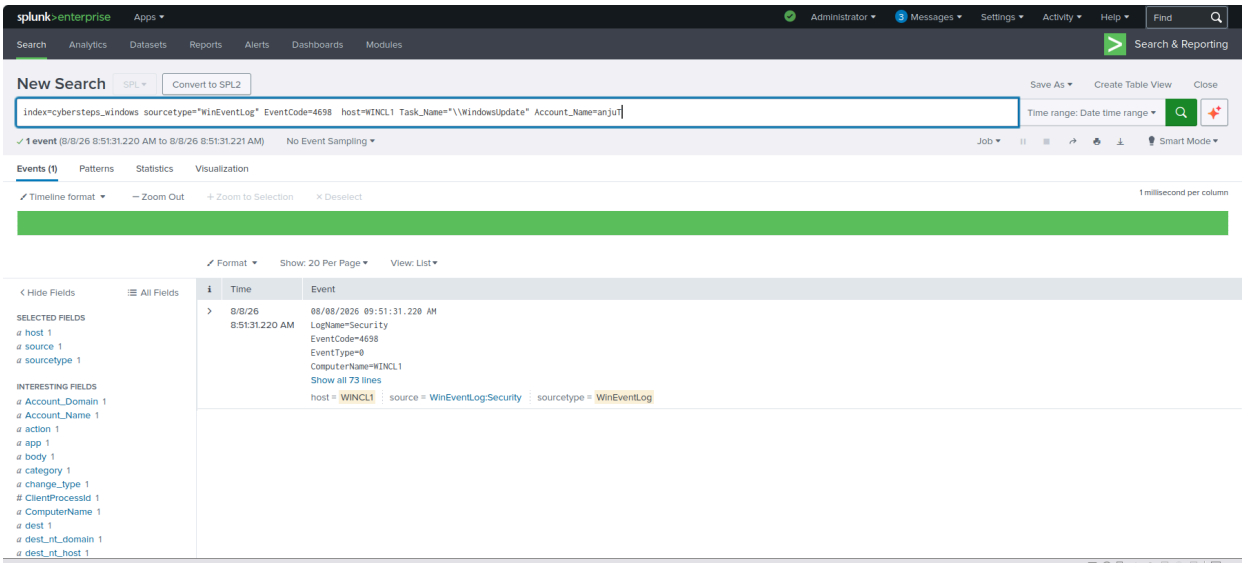
- `Account_Name`: test_account
- `host`: `WINCL1`

Three signals combine to confirm malicious intent: the task runs a binary from `C:\Users\Public\` (a user-writable path), it executes at logon (guaranteed execution), and it runs as SYSTEM (maximum privilege). The task name `WindowsUpdate` mimics a legitimate Windows component.

SPL used:

```
index=cybersteps_windows sourcetype="WinEventLog" EventCode=4698
| table _time, host, Task_Name, Account_Name, Command
| sort -_time
```

Screenshot: EventCode 4698 result showing \WindowsUpdate task created by test_account:



4.4 Detection Points

Detection	Fired	Evidence Confirmed
Detection #1 — Path Enumeration	✓	4,615 requests, not_found_ratio=99.9%, forbidden_count=34
Detection #3 — Web Login Flood	✓	353 POSTs to /api/auth/login from 10.10.10.40 (Hydra's '175 valid' was a false positive)
Detection #2 — Brute Force Logons	✓	233 EventCode 4625 events from 10.10.10.40 (Administrator; 68 bad password + 165 locked out)
Detection #4 — Suspicious Process	✓	Sysmon EID1: svchost.exe from C:\Users\Public, parent=powershell.exe

Detection	Fired	Evidence Confirmed
Detection #5 — Scheduled Task	✓	EventCode 4698: \WindowsUpdate, C:\Users\Public\update.exe, SYSTEM
Detection #6 — Port Scan	✓	1,000 distinct destination ports from 10.10.10.40 (WFP 5156/5157/5152)

4.5 Final Classification

True Positive — Confirmed Simulated Attack Campaign

All five original detections fired on real adversarial activity generated from `10.10.10.40` (Kali); a sixth (port scan, T1046) was added afterward for network visibility. The attack followed a deliberate kill chain: reconnaissance (gobuster), credential access (Hydra web login flood and SMB brute force), execution (masquerading binary), and persistence (scheduled task). No activity from `10.10.10.40` represents legitimate business activity.

4.6 Recommendations

Immediate:

- Enforce account lockout policy to limit brute force effectiveness (`net accounts /lockoutthreshold:5`)
- Disable the Administrator account when not required (`net user Administrator /active:no`)
- Remove the `WindowsUpdate` scheduled task (`schtasks /delete /tn "WindowsUpdate" /f`)
- Change the default portal admin password from `admin123`

Short-term:

- Restrict SMB (port 445) to management networks only — no direct access from workstations
- Require MFA on all privileged accounts and web application logins
- Apply an AppLocker or WDAC policy blocking execution from `C:\Users\Public\` and `%TEMP%`
- Add YARA or hash-based detection for known attack tools

Long-term:

- Extend log coverage to include firewall/network logs for lateral movement detection — implemented via Windows Filtering Platform auditing (see Detection #6)
- Add a Splunk Notable Events workflow for alert triage so detections feed an analyst queue
- Deploy Windows Defender Credential Guard to protect against credential extraction

- Conduct regular purple-team exercises using this same kill chain to validate detections still fire after environment changes

---

5. Appendix — SPL Query Library

These eight queries were built and tested against live lab data as part of the Task 5 (Query and Peace) exercise.

Q1 — All WINCL1 events, last 24h, as a table

```
index=cybersteps_windows host=WINCL1 earliest=-24h
| table _time, host, sourcetype, EventCode
```

Use: situational awareness view of everything one endpoint reported today.

Q2 — Count events by sourcetype across all indexes

```
index=cybersteps_*
| stats count by sourcetype
```

Use: pipeline health check — confirms every source is flowing and shows relative volume.

Q3 — Top 10 EventCodes from WINCL1

```
index=cybersteps_windows host=WINCL1
| top limit=10 EventCode
```

Use: reveals normal endpoint behaviour; anomalies stand out against the baseline.

Q4 — WEB1 auth.log events sorted by time

```
index=cybersteps_linux host=web1 source="/var/log/auth.log"
| sort _time
```

Use: chronological authentication audit trail on the web server.

Q5 — Nginx access events by hour

```
index=cybersteps_web sourcetype="nginx:access"
| timechart span=1h count
```

Use: surfaces traffic spikes over time; a sudden spike indicates scanning or a flood.

Q6 — Anything in cybersteps_linux containing "failed"

```
index=cybersteps_linux failed
```

Use: fastest triage for failed logins and failed sudo across the Linux index.

Q7 — Unique hostnames seen in last 7 days

```
index=cybersteps_* earliest=-7d
| dedup host
| table host
```

Use: confirms which machines are reporting; a missing host may indicate a forwarder outage.

Q8 — Add a day-of-week field with eval

```
index=cybersteps_*
| eval day_of_week=strftime(_time, "%A")
| table _time, host, day_of_week
```

Report prepared as part of the Operation Watchtower SOC project. All attacks were simulated in an isolated lab environment.